
Vulnerability Assessment Report:

PaySecure Solutions

Executive Summary

The vulnerability assessment of PaySecure Solutions' IT infrastructure identified **two critical**, **three high**, and **one medium-risk** vulnerability. The most significant risks involve the **Cisco Firepower Firewall** and the **Payment Processing Server**, both of which possess vulnerabilities that could allow unauthorized access to the entire network or the theft of sensitive financial data.

Immediate remediation is required for the firewall firmware and SQL Server patching to ensure compliance with GLBA and to prevent potential data breaches. Failing to address these issues could result in regulatory penalties, loss of customer trust, and significant financial liability.

Scope

The scope of this assessment included the following systems:

- **Perimeter Security:** Cisco Firepower 1010 Firewall.
- **Data Processing:** Windows Server 2022 (SQL Server 2019).
- **Web Services:** Ubuntu 22.04 (Apache/Node.js).
- **Storage:** Debian 11 (Samba File Services).
- **Communication:** CentOS 8 (Postfix).
- **Endpoints:** 100 Windows 10 Workstations.

The primary objectives were to identify security gaps affecting systems that handle **Nonpublic Personal Information (NPI)** and to align the organization with GLBA Safeguards Rule requirements.

Asset Inventory

Asset Name	OS/Software	Description	Importance Level

Payment Processing Server	Win Server 2022 / SQL 2019	Handles real-time digital transactions.	Critical
Firewall & Gateway	Cisco Firepower 1010	Perimeter defense and traffic filtering.	Critical
Document Mgmt Server	Debian 11 / Samba	Stores sensitive customer financial docs.	High
Customer Access Server	Ubuntu 22.04 / Node.js	Public-facing portal for account access.	High
Email Server	CentOS 8 / Postfix	Internal and external communications.	Medium
Employee Devices	Windows 10	Standard staff workstations (100 units).	Medium

Vulnerability Findings

System/Asset	Vulnerability	CVSS	Potential Impact	Severity
Firewall Appliance	Outdated firmware/Weak ACLs	9.5	Network-wide compromise; unauthorized entry.	Critical
Payment Server	SQL Server missing patches	9.2	Data theft; manipulation of payment records.	Critical

Customer Server	Node.js Outdated (RCE)	8.8	Remote take-over of the web server.	High
Doc Mgmt Server	Samba Guest Access	7.5	Unauthorized access to sensitive NPI docs.	High
Email Server	Weak Postfix Encryption	7.0	Interception of sensitive communications.	High
Employee Devices	Lack of Disk Encryption (20)	6.8	Data exposure if hardware is lost or stolen.	Medium

Vulnerability Analysis

The vulnerabilities were prioritized based on the "Path of Least Resistance" for an attacker.

1. **The Firewall (9.5)** is the top priority because it represents the first line of defense. A compromise here renders all internal controls moot.
2. **The Payment Processing Server (9.2)** follows immediately, as it contains the organization's "crown jewels"—the actual financial transaction data.
3. **The Customer Access Server (8.8)** is prioritized due to its public-facing nature; it is the most likely target for automated exploitation scripts.
4. **Samba and Email** vulnerabilities represent internal risks where an attacker who has already gained a foothold could escalate their access or exfiltrate data.

The lack of disk encryption on 20 devices is a direct violation of GLBA's physical and technical safeguard requirements, posing a high risk in the event of physical theft.

Remediation Recommendations

Priority	Vulnerability	Recommendation	Estimated Effort

1	Firewall Firmware	Update firmware to the latest stable version and audit ACL rules to close unnecessary ports.	Medium
2	SQL Server Patches	Apply latest Microsoft Security updates and Cumulative Updates (CU).	Low
3	Node.js Update	Update Node.js to the latest LTS version and remediate RCE vulnerabilities.	Medium
4	Samba Config	Disable guest access; implement Role-Based Access Control (RBAC) for all shares.	Low
5	Disk Encryption	Enable BitLocker on the 20 identified devices and centralize key management.	Low
6	Postfix Hardening	Enforce TLS 1.2+ for all email transmissions and update configuration.	Medium

Task 7: Continuous Monitoring Plan

To move beyond reactive patching and ensure long-term GLBA compliance, PaySecure Solutions should implement the following:

1. **Automated Vulnerability Scanning:** Deploy a tool (e.g., Nessus or OpenVAS) to perform weekly internal and external scans, ensuring new "shadow IT" or unpatched services are caught immediately.
 2. **SIEM Implementation:** Integrate a Security Information and Event Management (SIEM) system to aggregate logs from the Cisco Firewall, SQL Server, and Ubuntu servers to detect anomalous behavior in real-time.
 3. **Security Awareness Training:** Conduct quarterly phishing simulations and GLBA-specific data handling training for all 100 employees to mitigate the risk of social engineering.
-

Conclusion

This assessment identified significant security gaps that currently leave PaySecure Solutions vulnerable to both external attacks and regulatory scrutiny. By addressing the **Firewall** and **Payment Server** vulnerabilities within the next 48 hours, the organization will significantly reduce its immediate risk profile. Implementing the remediation steps outlined above will satisfy the technical requirements of the GLBA Safeguards Rule.

A follow-up validation scan is recommended within **30 days** to ensure all remediation efforts were successful.